

ICT3216

Introduction to Ethical Hacking

Group Assignment 05



Department of Computing | Faculty of Applied Sciences
Rajarata University of Sri Lanka

Submission Date: 28th March 2026

Group Name: Ethical_Strikers

SECURITY ASSESSMENT REPORT: SQL INJECTION VULNERABILITY

1. Executive Summary

This report documents a technical security assessment conducted to identify and exploit web-based vulnerabilities in a controlled environment. Using Kali Linux as the attack platform and Metasploitable 2 as the target, we successfully demonstrated a SQL Injection (SQLi) attack on the Damn Vulnerable Web Application (DVWA). The assessment confirms that an attacker can bypass authentication logic and extract sensitive user records from the backend database if proper input sanitization is not implemented.

2. Project Scope

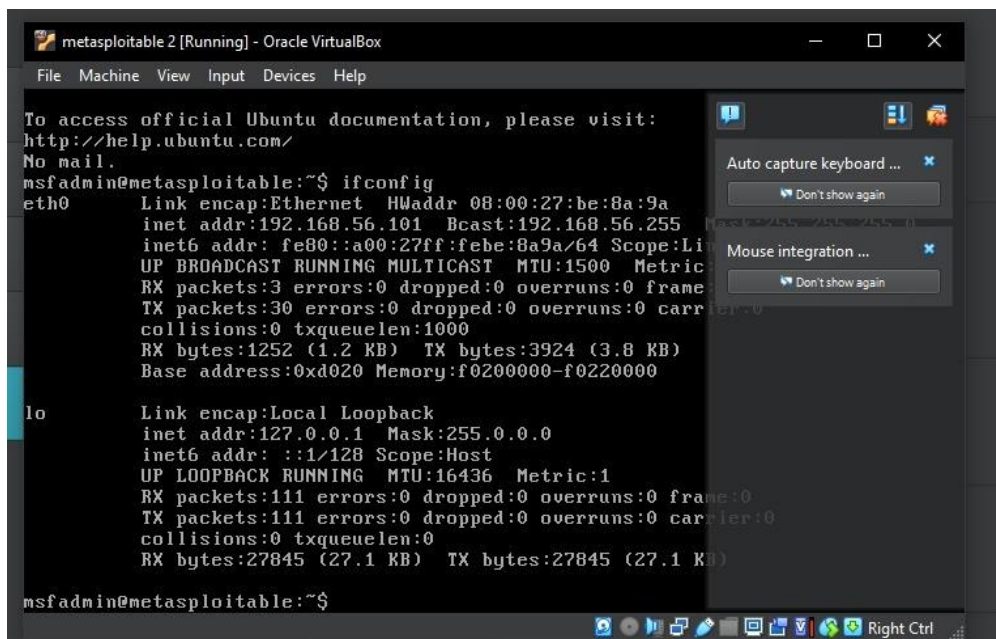
The scope of this penetration test was limited to the following assets:

- Target OS: Metasploitable 2 (Linux-based vulnerable VM)
- Target IP Address: 192.168.56.101
- Application: DVWA (SQL Injection Module)
- Security Configuration: Low Level

3. Reconnaissance & Target Identification

3.1. Target IP Verification

To begin the process, the target machine was identified within the local host-only network. By executing the `ifconfig` command on the Metasploitable terminal, the IP address was confirmed as 192.168.56.101.



```
metasploitable 2 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:be:8a:9a
          inet addr:192.168.56.101  Bcast:192.168.56.255
          inet6 addr: fe80::a00:27ff:febe:8a9a/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3 errors:0 dropped:0 overruns:0 frame:0
          TX packets:30 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1252 (1.2 KB)  TX bytes:3924 (3.8 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:111 errors:0 dropped:0 overruns:0 frame:0
          TX packets:111 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:27845 (27.1 KB)  TX bytes:27845 (27.1 KB)

msfadmin@metasploitable:~$
```

Figure 1: Verification of the target machine's IP address (192.168.56.101)

3.2. Network Scanning

Using **Nmap**, a comprehensive scan was performed to identify open ports and services on the target.

- Command: `nmap -sV 192.168.56.101`
- Results: The scan identified Port 80 (HTTP) as open, running an Apache web server, which serves as the primary attack vector for this assessment.

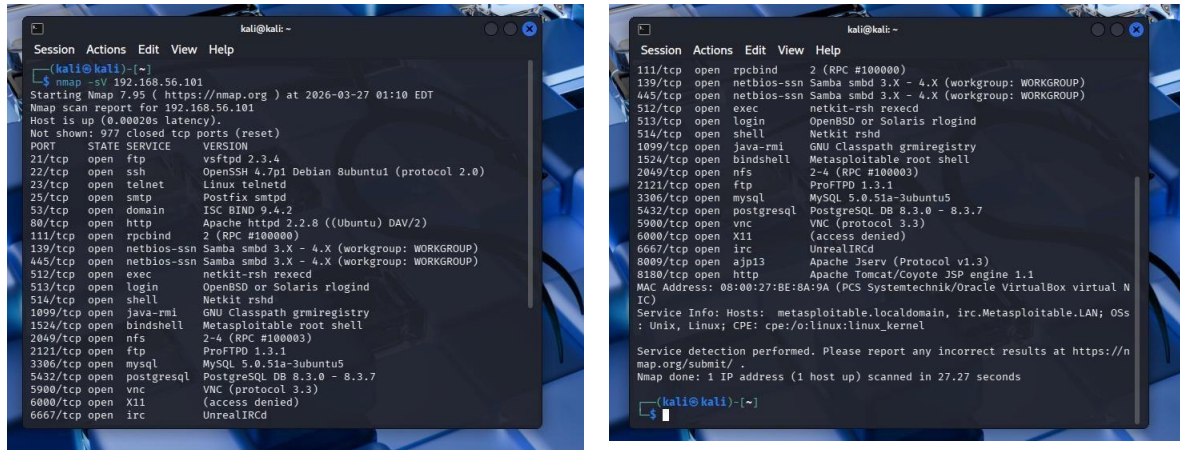


Figure 2: Nmap service scan results identifying Port 80 as open.

3.3. Accessing DVWA & Configuration

After identifying the web service, we accessed the DVWA login page via the Firefox browser on Kali Linux. We logged in using the default credentials (admin/password) and configured the DVWA Security level to 'Low' to begin the vulnerability assessment.

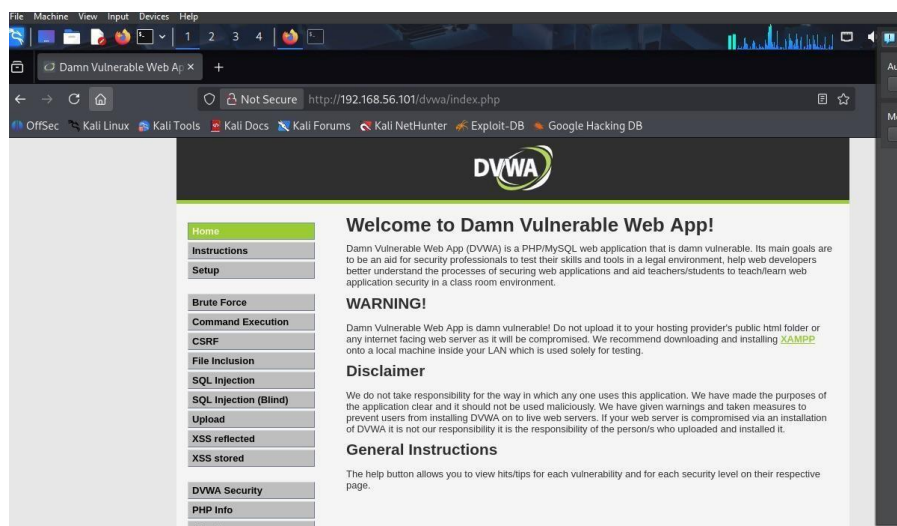


Figure 3: Accessing the DVWA interface and setting security level to Low

4. Exploitation Process

4.1. Vulnerability Discovery

We accessed the DVWA interface via a web browser and navigated to the SQL Injection section. To test if the input field was vulnerable, a single quotation mark (') was submitted in the "User ID" field.

- Observation: The system returned a MySQL error message. This confirms that the application is directly passing user input to the database query without validation, making it vulnerable to injection.

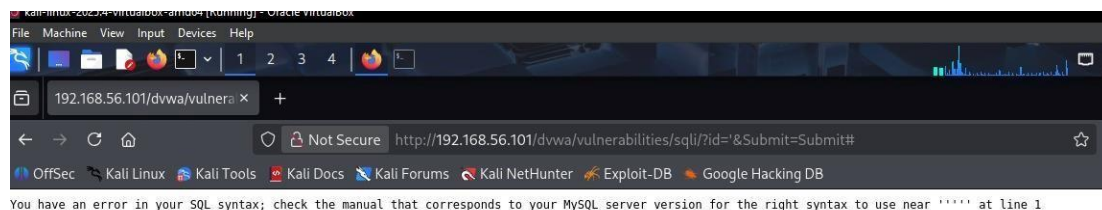


Figure 4: Triggering a database error to confirm SQL Injection vulnerability

4.2. Executing the Exploit

To extract unauthorized data, a specialized SQL payload was injected.

- Payload Used: ' OR '1'='1
- Mechanism: This payload forces the SQL WHERE clause to always evaluate as true.
- Outcome: The application bypassed the intended logic and returned the First Names and Surnames of all users stored in the database.

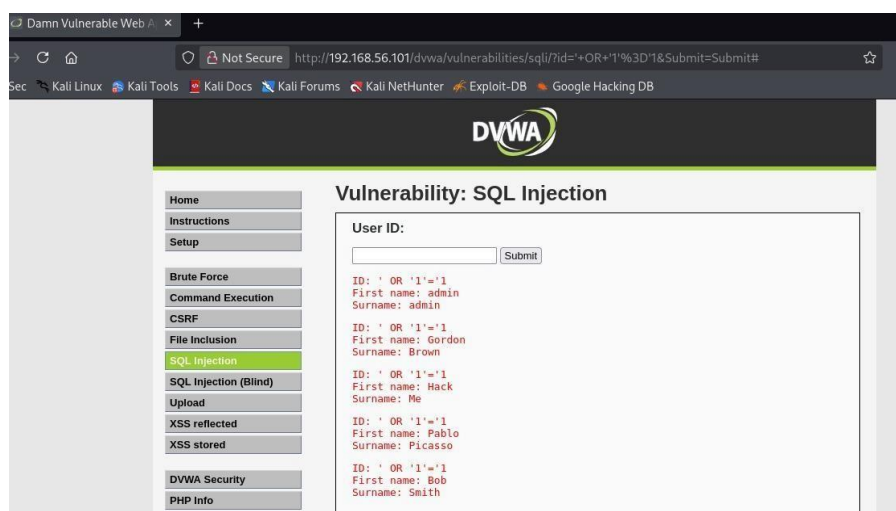


Figure 5: Successful data extraction showing all database user records

5. Risk & Impact Analysis

The identified SQL Injection vulnerability is rated as Critical.

- Data Leakage: Attackers can dump entire user tables, including sensitive personal information.
- Authentication Bypass: Unauthorized individuals can gain access to restricted areas of the application.
- Integrity Damage: Beyond reading data, an attacker could potentially modify or delete database entries.

6. Remediation Recommendations

To mitigate this vulnerability, we recommend the following security controls:

1. Use Prepared Statements (Parameterized Queries): This is the primary defense. It ensures that the database treats user input strictly as data and never as executable code.
2. Input Validation: Implement a whitelist for user inputs (e.g., ensuring the ID field only accepts numeric characters).
3. Principle of Least Privilege: Configure the database user account to have the minimum permissions required for the application to function.

7. Tools Used

- Nmap: For network discovery and service fingerprinting.
- Firefox: For manual interaction with the vulnerable web application.
- VirtualBox: To host the isolated lab environment (Kali & Metasploitable).
- Metasploitable 2: A purposefully vulnerable target server.

8.Task Allocation

Member Name	Reg. No & Index No	Task Assigned
S.R.D.M.S. Mahindasena	ICT/2021/068 5227	Vulnerability research, SQL Injection payload identification, and DVWA environment configuration.
S.N. Mapitigama	ICT/2021/069 5228	Exploit execution, SQL injection payload testing, and successful data extraction verification.
T.L. Kumarasiri	ICT/2021/150 5303	Reconnaissance using Nmap, target IP identification, and open port/service analysis.
K.A.D. Senadi	ICT/2021/109 5264	Risk and impact analysis, remediation recommendations, and report documentation.